

Çalışma Planı

Güvenlik & Mimari Düzeltmeleri — Denizcilik Şirketi Uygulaması

Kaynak: Proje-Degerlendirme-Raporu.docx	Çalışma tarzı: Kodu Onur yazar, Claude yönlendirir	Tarih: 30.07.2026
---	---	-----------------------------

Not: Bir günü bitirince [] kutucuğunu [x] yap. Sıralama akıllıdır: önce her yerde kullanılacak temel parçalar, sonra tek tek uygulama.

Gün 1 — Temeller: Ortak DB + JWT anahtarı

Amaç: Dağınık neon() bağlantılarını tek lib/db.ts'e topla + JWT sabit yedek anahtarını kaldır (G-04).

- [] lib/db.ts gözden geçir (tek export edilen sql)
- [] middleware.ts — JWT_SECRET yedeğini kaldır, env yoksa hata fırlat
- [] lib/auth.ts — aynı düzeltme
- [] Test: giriş yap/çık çalışıyor mu

Öğrenilecek: DB ve oturum bağlantısı nasıl kuruluyor, tek kaynak (encapsulation) neden önemli.

Gün 2 — Yetki helper'ı (RBAC'in kalbi)

Amaç: "Bu kullanıcı bu şirkette bu işlemi yapabilir mi?" sorusunu tek fonksiyonda topla.

- [] lib/authz.ts oluştur → requireCompanyAccess(userId, companyId, action)
- [] lib/permissions.ts ile birleştir (sahiplik + rol)
- [] Test: viewer rolüyle yazma denemesi engelleniyor mu

Bağlı bulgular: M-01, G-02, G-03 çözümünün temeli.

Gün 3 — IDOR + korumasız yetki sayfaları

Amaç: G-03 (ekip üyesi silme) + G-02 (roles/permissions rotaları).

- [] companies/[id]/team/[memberId]/route.ts — sahiplik doğru
- [] app/api/roles/** — auth + admin yetkisi ekle
- [] app/api/permissions/** — auth + admin yetkisi ekle

Gün 4 — Dosya yüklemeyi güvene al

Amaç: G-01 + G-06.

- [] app/api/upload/** — auth ekle
- [] Sunucu tarafı dosya tipi/boyut doğrulaması
- [] Blob erişimini gözden geçir (private mümkün mü)

Gün 5 — Auth'suz kalan rotaları kapat

Amaç: G-05.

- [] app/api/*/import/** (ships, invoices, voyages, fixtures)
- [] app/api/voyage-calculator/**
- [] Her rota için 'public olmalı mı?' kararını not et

Gün 6 — Giriş güvenliği

Amaç: G-07 + G-08.

- [] signin — deneme sınırı (rate limit)

[] signup + davet kabul — parola politikası + e-posta doğrulama

Gün 7 — Kalite: tip kontrolü + log temizliği

Amaç: K-01 + G-09.

[] next.config.mjs — ignoreBuildErrors kaldır, çıkan hataları düzelt

[] Tüm [v0] / PII içeren console.log temizle

Sona bırakıldı: tip kontrolü açılınca önceki günlerde düzeltilen dosyalar temiz çıkar.

Gün 8 — Standartlaştırma + ilk testler

Amaç: M-03 + K-02.

[] Tüm rotalarda tek auth yaklaşımı (requireAuth)

[] favorites rotasındaki iç fetch anti-pattern'ini düzelt

[] Kritik akış için 1-2 test

İlerleme notlarını CALISMA-PLANI.md dosyasına yazarak her gün nerede kaldığımızı işaretleyelim.